

07

Compliance, when it matters

HIPAA, SOC 2, GDPR. When you genuinely need them, when you don't, and what compliant actually requires.

SUBJECT REGULATION · TRUST PAPERWORK
AUTHOR MICAH JONES
TIME A SIX-MINUTE READ

READER SOLO BUILDERS ON AI TOOLS
STATUS CHAPTER SEVEN OF TEN
REV 2026.08

The two ways builders get this wrong

Compliance breaks solo builders in opposite directions. Half ignore it entirely and ship health data through consumer tooling with a shrug. The other half freeze: they have a genuinely good idea near a regulated space and never build it, because the acronyms feel like a wall only companies with lawyers climb.

Both failure modes come from the same misunderstanding: that compliance is a mysterious purchased credential. It mostly is not. It is the chapter-three map and the chapter-five locks, with paperwork attached, applied where the law actually reaches you. I built a HIPAA-compliant app alone. Not because I am a lawyer, but because the requirements, read calmly, turned out to be a list, and lists are what this manual does.

Which of these actually applies to you

Three acronyms cover most of what a solo SaaS will ever meet. Each has a one-question test.

§ 07.1

FIELD NOTE

Honesty first: this chapter is a field guide from a builder, not legal advice. When real money or real patient data is on the line, one hour with a healthcare or privacy attorney is cheap insurance, and this chapter makes that hour ten times more productive.

§ 07.2

Do you store or move identifiable health data on behalf of providers or plans?	HIPAA · NOW BAA's with every vendor touching that data, access controls, audit trail, breach plan.
Can EU or UK residents sign up for your public app?	GDPR BASICS · NOW Honest privacy policy, data export and deletion on request, vendor DPAs.
Is an enterprise buyer's questionnaire blocking a real deal?	SOC 2 · WHEN ASKED An audit report you buy when revenue justifies it. Until then: a one-page security summary.

HIPAA is United States health-data law, and the test is precise: it reaches you when you store or transmit individually identifiable health information on behalf of providers, plans, or their partners. A meditation app with self-reported moods is usually outside it. A tool where clinicians, doulas, or therapists manage client records is inside it, and inside means the full lane above.

GDPR (and its cousins, like California's CCPA) is about personal data generally, and its test is almost a formality: if EU residents can sign up, assume it applies. The solo-scale core is smaller than its reputation: tell the truth about what you collect, be able to hand a user their data, be able to delete it, and have agreements with the vendors who process it for you.

SOC 2 is the odd one out: not a law at all. It is an audit report enterprises request during procurement, a trust document with an invoice attached, typically five figures a year once auditors and tooling are in. The test is brutally practical: is a real deal, with real revenue, blocked by a questionnaire demanding it? If not, do not buy it on spec. A one-page

security summary describing your chapter-five practices answers most questionnaires a solo builder will see.

§ 07.3

What “compliant” actually requires

Strip the acronyms and the same skeleton sits under all three. You already met most of it.

Know where the data lives: the five-box map from chapter three, drawn and current. Control who sees it: chapter five’s row-level security and the two-account test, which double as HIPAA’s “access controls” in a form an auditor can read. Encrypt in transit and at rest, which modern platforms do by default; your job is to verify, not to build. Keep an audit trail of who touched what. Be able to export and delete a person’s data on request. Put agreements in place with every vendor that touches the data. Write down what you do, and then do what you wrote down.

That last sentence is the entire spirit of the thing. Compliance failures are rarely exotic. They are gaps between the policy and the practice, and a solo builder has one advantage no enterprise has: the policy and the practice live in the same head.

Compliance is the napkin, plus the locks, plus paperwork. You built the first two chapters ago.

§ 07.4

The vendor chain is the real exam

Here is the part that decides most of it at solo scale: you inherit compliance through your vendors. Your app is as compliant as the weakest agreement in the chain.

Under HIPAA the agreement is a **BAA**, a business associate agreement, and every vendor that touches identifiable health data must sign one: your hosting, your database, your file storage, your email sender, your error logger. The big platforms sign them, some only on certain tiers. Plenty of

consumer-grade tools never will, and one convenient no-BAA tool in the chain, one crash-reporting service that captures a record, one email API relaying an appointment reminder, quietly breaks the whole thing.

Under GDPR the same role is played by the **DPA**, the data-processing agreement, and the mainstream vendors bundle one into their standard terms. Your work is mostly to collect and file them, and to notice the vendor that has none.

So the exam is an afternoon, not a year: take the chapter-three map, list every vendor on it, and put a checkmark or an X next to each. The X's are your work: replace the vendor, upgrade the tier, or keep that category of data away from it.

FROM THE BUILD LOG

ENTRY • 2026-08-30

The stack I stopped naming

While polishing the public case study about my own health app, a review caught something I had walked past: the page proudly named the exact infrastructure the app runs on, vendor by vendor.

Read as marketing, it was credibility. Read as an attacker, it was a map: knowing precisely which platforms power a health app tells you which known vulnerabilities to try, which login pages to spray, which status pages to watch for a bad week.

Every vendor name came off the page the same day. The architecture napkin is for you, your spec, and your auditors. The public version says what the system does and what protects it, never which brands it is assembled from. Confidence talks about properties. Only carelessness publishes the parts list.

FIELD NOTE

Ordani, the HIPAA-compliant app from these pages, came down to exactly this: a vendor chain where everything touching client data carries the right agreement, ownership enforced in the database, and the two-account discipline from chapter five. Two outside security reviews later, the design holds.

Pre-flight: the paperwork pass

PRE-FLIGHT • COMPLIANCE

RUN TONIGHT

- ☐ **Answer the three questions** in the diagram, in writing, in your spec's NOT or NOW section: health data for providers, EU users, enterprise questionnaires. Most readers get one yes, not three.

- ☐ **Run the vendor sweep.** Every vendor on your chapter-three map gets a DPA checkmark, plus a BAA checkmark if health data is in play. Any X becomes a replacement or an upgrade, this week.

- ☐ **Write the honest privacy policy:** what you collect, why, how long you keep it, and how a user gets it exported or deleted. Plain language beats borrowed legalese you don't actually do.

- ☐ **Make deletion a query, and prove it.** On a test account, delete one user's everything: rows, files, logs that identify them. Chapter three's owner column is why this is an evening, not a quarter.

- ☐ **Hold the SOC 2 line.** Keep a one-page security summary for questionnaires, and buy the audit the day a real contract makes it worth it, not the day the anxiety does.

The data is mapped, locked, and papered. The app deserves to exist in public. Which raises the question this book has been saving: where do the first ten people who pay for it actually come from?

The first ten users

Getting to the first ten people who keep using it. Where they come from, and why posting stopped working.